POC: Private Exposure Registry-ו מחקר · Case 02

לפי תבנית "מסמך מחקר ו-POC" של מגשימים: מחקר בסיסי, חמישה פיצ'רים מרכזיים, וה-POC הראשון (יעדים, תכנית, דיזיין, מימוש ומסקנות). כל POC נכתב בפייתון, הורץ בפועל, והמספרים כאן הם הפלט שלו. בכל POC מצוין במפורש מה אמיתי ומה מדומה.

מחקר בסיסי: רצף האירועים

- **הכנה מקומית:** כל משתתף (קרן, או רגולטור בשם הקרנות שלו) מחשב אצלו את הנתונים לפי תבנית אחידה: חשיפה בדולרים לפי מדרגת ריבית ולפי ענף, ומדרגת המנוף שלו. הנתונים הגולמיים לא יוצאים.
- **פיצול:** כל מספר מפוצל לשלושה חלקים אקראיים שסכומם שווה למספר (secret sharing). כל חלק נשלח לשרת אחר.
- **צבירה:** כל שרת מחבר את החלקים שקיבל מכל המשתתפים. אף שרת לא רואה ערך של אף משתתף, רק רעש.
- **בדיקת סף:** לכל תא נספרים המשתתפים (גם הספירה מחושבת באותה שיטה). תא עם פחות מ-5 משתתפים לא ייחשף.
- **רעש פרטיות:** כל שרת מוסיף רעש מבוקר (Differential Privacy) לחלק שלו, כדי שהתשובה המצרפית לא תסגיר משתתף בודד.
- **פתיחה:** רק התוצאה המצרפית נפתחת, כששלושת השרתים משלבים את החלקים שלהם.

מחקר בסיסי: רכיבי המערכת

- **Participant Client:** מחשב את התבנית מקומית ומפצל.
- **Compute Servers (שלושה, אצל גופים שונים):** צוברים חלקים, מוסיפים רעש.
- **Threshold Gate:** חוסם תאים קטנים.
- **Release Service:** משלב חלקים ומפרסם תוצאה לרגולטור.
- **Query Catalog:** רשימה סגורה של שאלות מותרות, כדי שאי אפשר יהיה לשאול שאלה שתוכננה לחשוף מישהו.

מחקר בסיסי: אתגרי אבטחה

- **קנוניה בין שרתים:** אם כל השרתים יחברו את החלקים שלהם, הם רואים הכול. ההגנה היא ארגונית: כל שרת אצל גוף אחר.
- **דליפה דרך התוצאה:** בתא עם שני משתתפים, כל אחד מהם יכול להחסיר את עצמו מהסכום ולגלות את השני. מכאן סף מינימלי ורעש.
- **משתתף משקר:** השיטה מגינה על סודיות, לא על אמת. משתתף יכול לדווח מספרים לא נכונים, ואף אחד לא יראה. זו שאלה פתוחה רצינית.
- **זמינות:** בשיטה שבה כל שלושת החלקים נדרשים, שרת אחד שנופל עוצר הכול.

מחקר בסיסי: השוואה למתחרה מוביל (Form PF ודיווח רגולטורי רגיל)

- **סודיות:** ב-Form PF הרגולטור רואה הכול. אצלנו אף אחד לא רואה נתון בודד.
- **שיתוף בין רשויות:** ב-Form PF הנתונים נשארים אצל ה-SEC. אצלנו כמה רשויות יכולות לחשב יחד בלי להעביר נתונים.

- **עומק:** Form PF מאפשר כל ניתוח על הנתונים הגולמיים. אצלנו רק השאלות שבקטלוג.
- **אמינות הדיווח:** ב-Form PF הרגולטור יכול לבקר ולבדוק. אצלנו קשה יותר לבדוק נתון שאף אחד לא רואה.

מסקנת ההשוואה: אנחנו מוותרים על גמישות ועל יכולת ביקורת, ומקבלים שיתוף שהיום בלתי אפשרי.

מחקר בסיסי: סוגיה אתית

מערכת שמבטיחה "אף אחד לא רואה" חייבת לעמוד בהבטחה. אם תתגלה דליפה, היא תפגע באמון בכל הכלים מהסוג הזה. מענה: קטלוג שאלות סגור, סף מינימלי, רעש מבוקר, ותיעוד פומבי של מה כן דולף (למשל מספר המשתתפים בכל תא).

חמישה פיצ'רים מרכזיים

- **תבנית דיווח:** קלט: ספר ההלוואות של המשתתף. פלט: וקטור אחיד (מדרגות ריבית כפול ענפים, ומדרגת מנוף). איך: קיבוץ מקומי וחיתוך (clipping) של כל תא לתקרה, כדי להגביל את ההשפעה של משתתף בודד.
- **פיצול סודות:** קלט: הווקטור. פלט: שלושה וקטורים אקראיים. איך: חיבור מודולרי מעל שדה ראשוני (2 בחזקת 61 פחות 1), עם מחולל אקראיות קריפטוגרפי.
- **צבירה בשרת:** קלט: חלקים מכל המשתתפים. פלט: סכום חלקי. איך: חיבור מודולרי בלבד, בלי לראות ערכים.
- **שער סף ורעש:** קלט: ספירת משתתפים לתא, סכום חלקי. פלט: תא מותר או חסום, וחלק עם רעש. איך: סף K=5, רעש Laplace בקנה מידה של התקרה חלקי אפסילון.
- **פתיחה ודוח:** קלט: חלקים משלושת השרתים. פלט: תשובות לשאלות הקטלוג (למשל אחוז החשיפה מעל 5%, ריכוז ענפי, היסטוגרמת מנוף). איך: שילוב החלקים וחישוב היחסים.

ה-POC: שאלת המחקר

האם אפשר לחבר נתוני חשיפה של מאות משתתפים לתמונה מצרפית מדויקת מספיק, כך שאף שרת לא יראה נתון בודד ושהתוצאה לא תסגיר משתתף, בזמן סביר?

ה-POC: יעדים

- **נכונות:** בלי רעש, התוצאה חייבת להיות זהה בדיוק לסכום האמיתי.
- **סודיות:** שרת אחד לבדו לא יכול להבחין בין ערך 0 לערך מיליון. שני שרתים מתוך שלושה לא יכולים לשחזר ערך.
- **הגנת תוצאה:** תא עם פחות מ-5 משתתפים נחסם. מדידת המחיר של הרעש בדיוק, בשלוש רמות פרטיות.
- **ביצועים:** 500 משתתפים בזמן סביר.

ה-POC: טכנולוגיות וגבולות

- Python טהור, עם secrets (אקראיות קריפטוגרפית) וחשבון מודולרי. בלי ספריות, כדי שירוץ בדפדפן.

- **גבול חשוב:** המשתתפים מדומים (500 קרנות אקראיות עם 7 ענפים, אחד מהם נדיר בכוונה). הקריפטוגרפיה אמיתית אבל פשוטה: שרתים "ישרים אך סקרנים" (מבצעים את הפרוטוקול, אולי מציצים), בלי הגנה מפני שרת זדוני, ושלושת השרתים רצים באותו תהליך.
- **החלטת תכנון:** המשתתפים מקבצים למדרגות אצלם, כך שהשרתים צריכים רק לחבר. השוואות ("האם הריבית מעל 5%?") יקרות מאוד בחישוב משותף, והקיבוץ המקומי חוסך אותן לגמרי.
- **מחוץ לגבולות:** הגנה מפני שרת זדוני (MACs כמו ב-SPDZ), רשת אמיתית, אימות שהמשתתף דיווח אמת.

ה-POC: תרשים זרימה

ספר הלוואות (נשאר אצל המשתתף) ← וקטור מקובץ וחתוך ← פיצול לשלושה חלקים ← שרת א / שרת ב / שרת ג (צבירה) ← ספירת משתתפים ← שער סף ← רעש ← שילוב ← תשובות הקטלוג.

ה-POC: תוצאות

- **נכונות:** בלי רעש, כל התאים יצאו זהים בדיוק לסכום האמיתי.
- **ביצועים:** 500 משתתפים, 33 תאים לכל אחד: פיצול, צבירה ופתיחה ב-0.11 שניות.
- **סודיות מול שרת בודד:** התפלגות החלקים שהשרת רואה עבור ערך 0 ועבור ערך מיליון זהה בגבול רעש הדגימה (פער מקסימלי של 0.65% בין עמודות היסטוגרמה, ב-20,000 דגימות).
- **סודיות מול שני שרתים:** שילוב שני חלקים מתוך שלושה החזיר מספר אקראי עצום. שילוב שלושתם החזיר בדיוק את הערך (777).
- **שער הסף:** שלושה תאים בענף הנדיר נחסמו אוטומטית. בדוגמת התקפה, משתתף בתא של שניים היה מגלה את הנתון של השני (65) בלי הסף, ועם הסף התא חסום.
- **מחיר הפרטיות:** באפסילון 1 (פרטיות חזקה) השגיאה החציונית בתא היא 2.2% והמקסימלית 7.9%. באפסילון 4, 0.6% ו-2%. באפסילון 16, 0.1% ו-0.5%. השאלה המרכזית, איזה אחוז מהחשיפה נמצא בריבית מעל 5%, יצאה 17.5% מול 16.8% אמיתי באפסילון 1, ו-17% באפסילון 4. גם בפרטיות החזקה, התשובה שימושית.
- היסטוגרמת המנוף באפסילון 4 יצאה כמעט זהה לאמת (שגיאה של משתתף אחד לכל היותר בתא).

ה-POC: מה אמיתי ומה מדומה

אמיתי: פיצול הסודות, הצבירה, הסף והרעש, וההוכחה שהם עובדים יחד. מדומה: המשתתפים והנתונים שלהם, והשרתים שרצים על אותו מחשב. הביצועים יהיו איטיים יותר ברשת אמיתית, ובהרבה עם הגנה מפני שרתים זדוניים.

ה-POC: מסקנות

✅ הקונספט הוכח: אפשר לחבר נתוני חשיפה של מאות משתתפים לתמונה מצרפית מדויקת, בלי שאף שרת יראה נתון בודד, ובפחות משנייה. אבל ה-POC חשף שתי שאלות שהקריפטוגרפיה לא עונה עליהן. הראשונה: השיטה מגינה על סודיות, לא על אמת. משתתף יכול לדווח מספרים לא נכונים. השנייה: מי מפעיל את שלושת השרתים, ומה קורה כשאחד מהם נופל. שתיהן עוברות לאפיון.